Report Tecnico: Simulazione di Campagna Spear Phishing

1. Introduzione e Obiettivi

Il laboratorio di oggi chiedeva di raggiungere il seguente obbiettivo:
● Progettare una campagna di phishing credibile con l'ausilio dell'intelligenza artificiale verso un target a nostra scelta.

Scenario: È stata simulata una campagna mirata ai clienti di **Poste Italiane**, utilizzando il framework **GoPhish** e il servizio **Mailtrap** per l'intercettazione sicura delle email in ambiente Kali Linux).

STEP 1: Preparazione dell'ambiente e Download del Framework

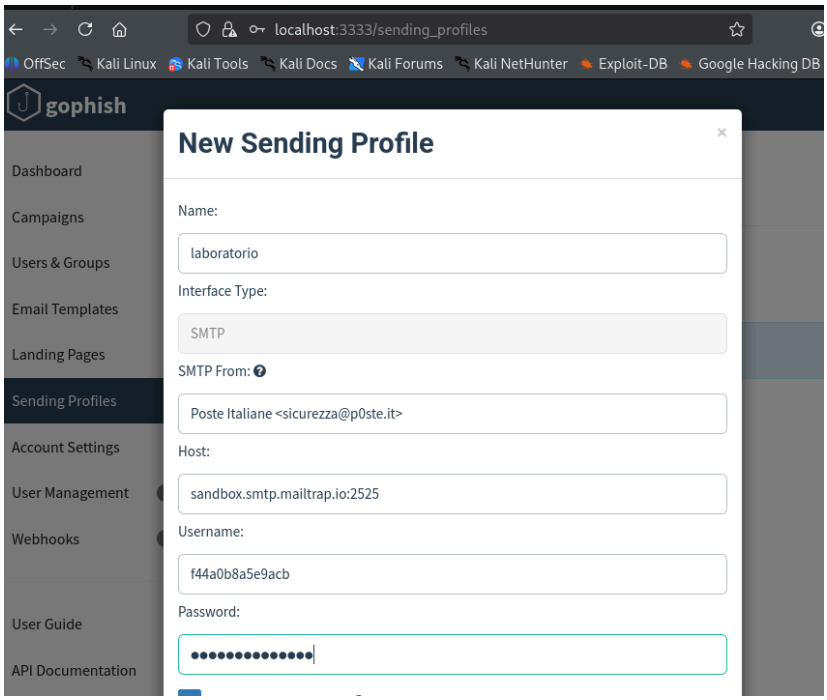
L'attività è iniziata con la preparazione dell'ambiente di lavoro all'interno di una macchina virtuale **Kali Linux**. Per l'orchestrazione della campagna di phishing è stato scelto **GoPhish**. Il software è stato scaricato direttamente dalla repository ufficiale di GitHub utilizzando il comando wget.

```
┌──(kali㉿kali)-[~]
└─$ wget https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip
--2026-04-02 19:00:13--  https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.z
ip
Resolving github.com (github.com)... 140.82.121.3
Connecting to github.com (github.com)|140.82.121.3|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/14508450/d275c2cd-8d50-49e6-
a442-fec1d3d0f1a3?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-04-02T23%3A33%3A41Z&rscd=attachment%3B+filename%3Dgophi
sh-v0.12.1-linux-64bit.zip&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a665
4-997b-47e9-b12b-9515b896b4de&skt=2026-04-02T22%3A33%3A41Z&ske=2026-04-02T23%3A33%3A41Z&sks=b&skv=2018-11-09&sig=WF
vSAYKHVDyd3%2BO3%2FMn%2BPR9K5AueOpoceUElKVTj3T4%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29
tIiwiYXVkIjoicmVsZWFzZS1hc3NldHMuZ2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3NTE3MjYxNCwibmJmIjoxNz
c1MTcwODE0LCJwYXRoIjoicmVsZWFzZWFzc2V0cHJvZHVjdGlvbi5ibG9iLmNvcmUud2luZG93cy5uZXQifQ.B9wVpSg2vHPGWRBKvWv6kik8LnSMlf
9zcYZMeaNr6yI&response-content-disposition=attachment%3B%20filename%3Dgophish-v0.12.1-linux-64bit.zip&response-cont
ent-type=application%2Foctet-stream [following]
--2026-04-02 19:00:13--  https://release-assets.githubusercontent.com/github-production-release-asset/14508450/d275
c2cd-8d50-49e6-a442-fec1d3d0f1a3?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-04-02T23%3A33%3A41Z&rscd=attachment%3B+f
ilename%3Dgophish-v0.12.1-linux-64bit.zip&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab
0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2026-04-02T22%3A33%3A41Z&ske=2026-04-02T23%3A33%3A41Z&sks=b&skv=20
18-11-09&sig=WFvSAYKHVDyd3%2BO3%2FMn%2BPR9K5AueOpoceUElKVTj3T4%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3Mi
OiJnaXRodWIuY29tIiwiYXVkIjoicmVsZWFzZS1hc3NldHMuZ2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3NTE3MjY
xNCwibmJmIjoxNzc1MTcwODE0LCJwYXRoIjoicmVsZWFzZWFzZ2V0cHJvZHVjdGlvbi5ibG9iLmNvcmUud2luZG93cy5uZXQifQ.B9wVpSg2vHPGWRB
KvWv6kik8LnSMlf9zcYZMeaNr6yI&response-content-disposition=attachment%3B%20filename%3Dgophish-v0.12.1-linux-64bit.zi
p&response-content-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.108.133, 185.199.1
10.133, 185.199.109.133, ...
Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com)|185.199.108.133|:443... c
onnected.
HTTP request sent, awaiting response... 200 OK
Length: 33327057 (32M) [application/octet-stream]
Saving to: 'gophish-v0.12.1-linux-64bit.zip'

gophish-v0.12.1-linux-64bit. 100%[===================================================>]  31.78M  8.70MB/s    in 3.8s

2026-04-02 19:00:17 (8.39 MB/s) - 'gophish-v0.12.1-linux-64bit.zip' saved [33327057/33327057]
```

STEP 2: Configurazione del Sending Profile e SMTP Relay

Per poter inviare le email di phishing in modo che non vengano bloccate immediatamente dai filtri antispam e per monitorarne l'invio in un ambiente protetto, è stato configurato un **Sending Profile**. In questa fase, GoPhish è stato collegato a **Mailtrap**, un servizio di SMTP Relay che funge da "server di posta virtuale".

Si può notare in questa schermata chè il campo **SMTP From**. È stato impostato come Poste Italiane <sicurezza@p0ste.it>. Si noti l'utilizzo della tecnica di **Typosquatting**: l'uso dello zero al posto della lettera "o" nel dominio p0ste.it. Questa differenza è spesso trascurata dagli utenti distratti, rendendo l'attacco estremamente credibile.

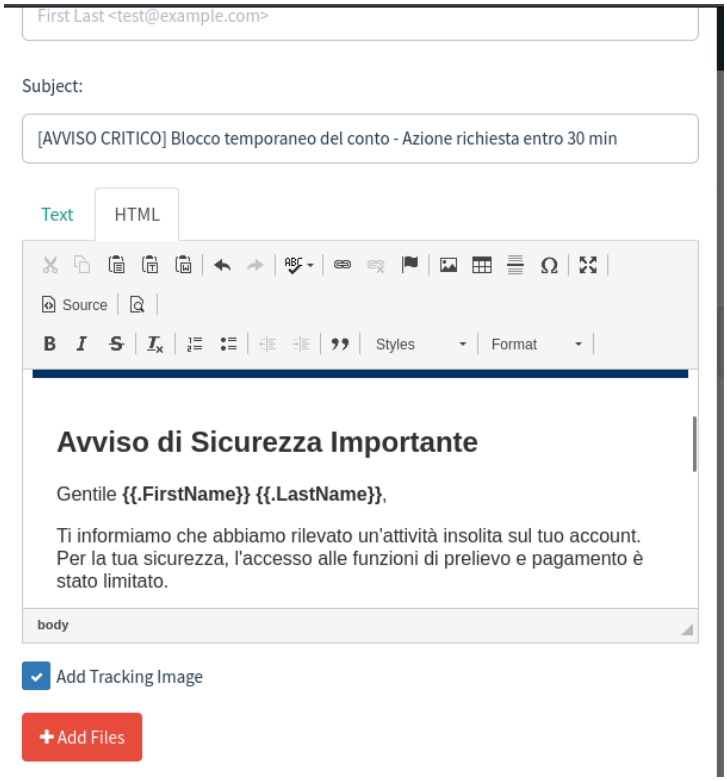


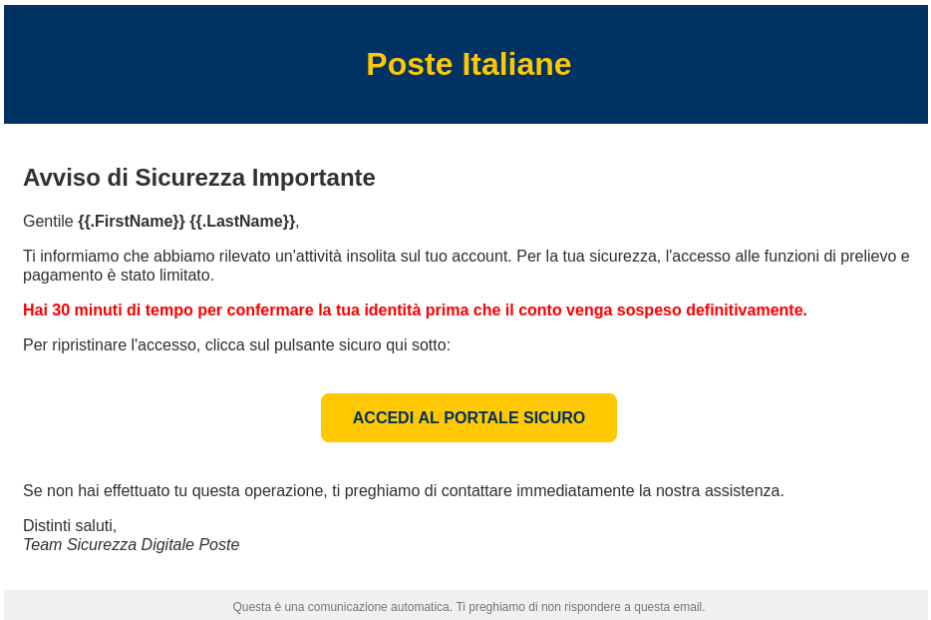
STEP 3: Creazione dell'Email Template (Social Engineering)

Una volta configurato il motore di invio, la fase successiva ha riguardato la progettazione dell'**Email Template**. Questo è il cuore dell'ingegneria sociale: il testo e la grafica devono essere abbastanza convincenti da spingere la vittima a compiere un'azione (cliccare sul link).

L'email è stata redatta replicando lo stile delle comunicazioni ufficiali di Poste Italiane. L'oggetto dell'email, [AVVISO CRITICO] Blocco temporaneo del conto..., è stato studiato per catturare immediatamente l'attenzione e generare **ansia**. Nel corpo del testo, l'uso del colore rosso per la frase *"Hai 30 minuti di tempo..."* introduce un forte elemento di **urgenza**, spingendola ad agire d'impulso prima di verificare l'autenticità del messaggio.

Inoltre, sono stati utilizzati dei **template tags** di GoPhish (come {{.FirstName}}), che verranno sostituiti automaticamente con il vero nome del destinatario durante l'invio. Questa personalizzazione trasforma un semplice phishing generico in un ben più pericoloso attacco di **Spear Phishing**.

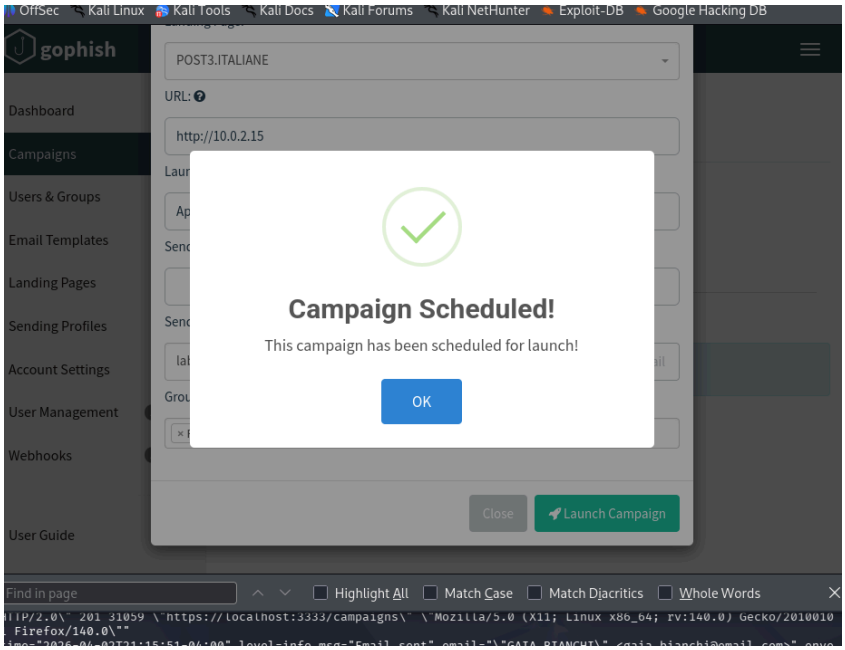




STEP 4: Gestione del Target e Lancio della Campagna

In questa fase finale di preparazione, è stato definito il perimetro dell'attacco. Attraverso la sezione **Users & Groups**, sono stati inseriti i destinatari della simulazione. In un attacco **Phishing**, questa lista è estremamente selezionata e i dati (nome, cognome, email) vengono spesso raccolti tramite tecniche di **OSINT** per aumentare la fiducia della vittima.

Il lancio della campagna è avvenuto impostando l'URL di destinazione sull'indirizzo IP locale della macchina attaccante (http://10.0.2.15), dove risiede la **Landing Page** clonato.



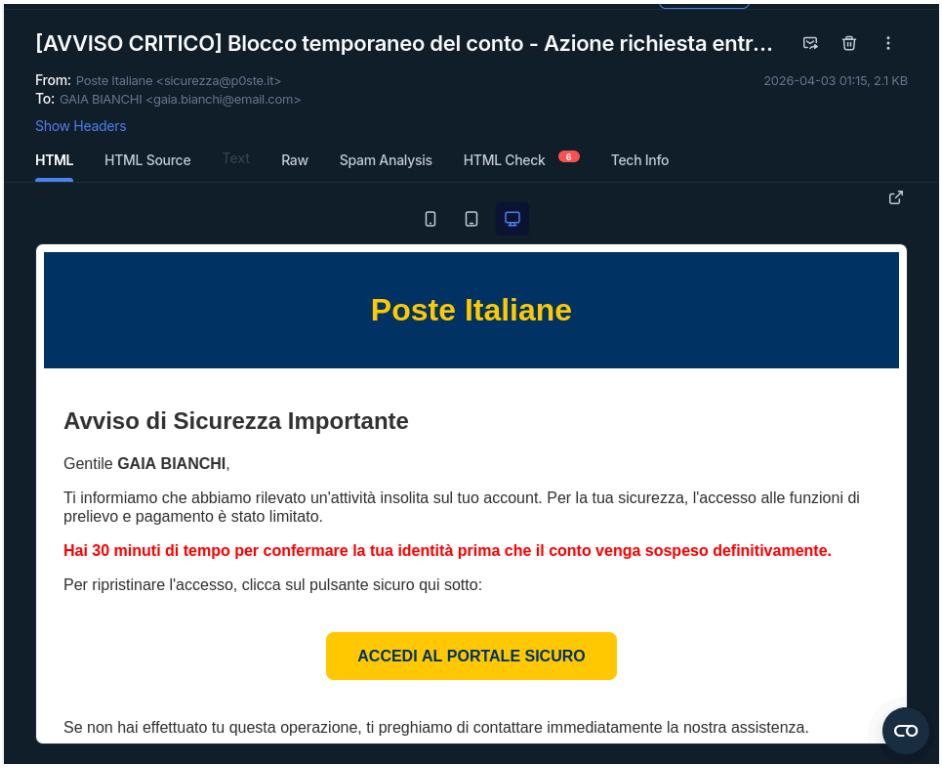
STEP 5: Esecuzione del Phishing e Cattura delle Credenziali

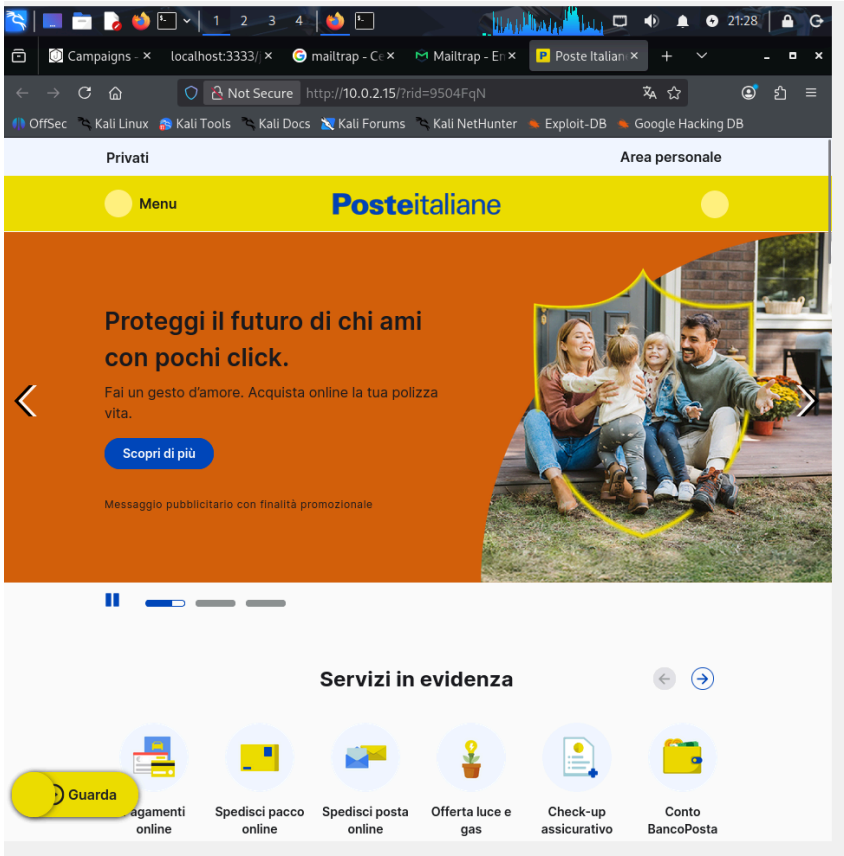
In questa fase finale, viene analizzato il comportamento della vittima e l'efficacia del portale contraffatto. Cliccando sul link contenuto nell'email, l'utente viene indirizzato a un sito web esteticamente identico a quello originale di Poste Italiane.

Tuttavia, un'analisi attenta,generalmente trascurata dalle vittime dato il senso di urgenza, rivela le anomalie:

1. **L'URL**: L'indirizzo non è poste.it ma l'indirizzo IP dell'attaccante (10.0.2.15).
2. Il browser segnala che la connessione non è sicura

Una volta che la vittima inserisce le proprie credenziali (Username e Password) nel modulo di login, il framework GoPhish intercetta i dati in tempo reale prima di reindirizzare l'utente sul sito reale per non destare sospetti. Il successo dell'operazione è confermato dalla Dashboard di controllo, dove le credenziali rubate sono visualizzate in chiaro.


[AVVISO CRITICO] Blocco temporaneo del conto - Azione richiesta entr...
From: Poste Italiane <sicurezza@p0ste.it>
To: GAIA BIANCHI <gaia.bianchi@email.com>
2026-04-03 01:15, 2.1 KB
Show Headers
HTML
HTML Source
Text
Raw
Spam Analysis
HTML Check
Tech Info
Poste Italiane
Avviso di Sicurezza Importante
Gentile GAIA BIANCHI,
Ti informiamo che abbiamo rilevato un'attività insolita sul tuo account. Per la tua sicurezza, l'accesso alle funzioni di prelievo e pagamento è stato limitato.
Hai 30 minuti di tempo per confermare la tua identità prima che il conto venga sospeso definitivamente.
Per ripristinare l'accesso, clicca sul pulsante sicuro qui sotto:
ACCEDI AL PORTALE SICURO
Se non hai effettuato tu questa operazione, ti preghiamo di contattare immediatamente la nostra assistenza.


Not Secure
http://10.0.2.15/?rid=9504FqN
Privati
Area personale
Menu
Posteitaliane
Proteggi il futuro di chi ami con pochi click.
Fai un gesto d'amore. Acquista online la tua polizza vita.
Scopri di più
Messaggio pubblicitario con finalità promozionale
Servizi in evidenza
Guarda
Spedisci pacco online
Spedisci posta online
Offerta luce e gas
Check-up assicurativo
Conto BancoPosta

Conclusione

Riflessione sull'IA: L'ausilio dell'intelligenza artificiale nella stesura dei testi ha permesso di eliminare errori grammaticali tipici dei vecchi attacchi di phishing, rendendo il messaggio estremamente professionale e difficile da distinguere da una comunicazione reale. Questo insegna quanto sia fondamentale la formazione e l'attuazione di contromisure per prevenire e riconoscere questi attacchi